1. UK Government Protective Marking Scheme

FRAMEWORK

The hierarchy of protection levels tested in the exam, ordered from lowest to highest protection:

```
Lowest protection
        ↓
NPM (Some protection needed)
PROTECT
RESTRICTED (More sensitive)
CONFIDENTIAL
SECRET
TOP SECRET
        ↑
Highest protection
```

2. Core Statutes High-Level Summary

CHEAT SHEET

Statute / Regulation	Core Focus	Key Sections / Articles	Maximum Penalties	Exam Trigger Scenario
Computer Misuse Act 1990 (CMA)	Unauthorized computer access, modification, and tool creation.	Sec 1, 2, 3, 3ZA, 3A	Up to Life Imprisonment (Sec 3ZA)	Scanning without authorization, running DoS payloads, exploiting unauthorized hosts.
Police and Justice Act 2006	Modernizing amendments to CMA 1990.	Amends Sec 3, adds Sec 3A, increases Sec 1 penalties.	Sec 1 raised to 2 yrs; Sec 3 to 10 yrs	"Which Act updated CMA to include Denial of Service and illegal tool making?"
Serious Crime Act 2015	Critical infrastructure and human safety protection.	Inserts Sec 3ZA into CMA 1990.	Life Imprisonment	Cyber-attack targeting hospital life-support, nuclear plants, or national power grids.
Data Protection Act 2018 & UK GDPR	Lawful processing and storage of PII.	Art 5 (Principles), Art 33 (Breach Reporting)	Greater of £17.5M (€20M) or 4% global turnover	Dumping entire customer databases instead of minimal sanitized records; unencrypted evidence.
Human Rights Act 1998	Protection of fundamental human rights.	Article 8 (Right to respect for private & family life).	Civil action / evidence challenge	Inadvertently opening or reading personal employee webmail on a target workstation.
RIPA 2000 / IPA 2016	Interception of telecommunications and packet data in transit.	Lawful Business Practice Regulations (LBPR)	Up to 2 years imprisonment	Inline packet sniffing, VoIP tapping, or ARP spoofing without written consent.
Copyright, Designs & Patents Act 1988	IP protection and software reverse engineering.	Software Directive Exceptions (Sec 50B/50BA)	Civil damages / criminal infringement	Decompiling commercial client binary files or copying proprietary code off-site without permission.
Communications Act 2003	Misuse of public electronic communication networks.	Section 127 (Improper / grossly offensive messages).	Up to 6 months imprisonment / fine	Sending aggressive, threatening, or obscene spear-phishing pretexts to corporate staff.
PCI DSS 4.0	Cardholder data environment (CDE) protection.	Requirement 11.4	Fines, loss of card processing capability	Annual external/internal pentest & after significant changes to e-commerce gateways.

3. Computer Misuse Act 1990 (CMA) Detailed Breakdown

CMA 1990

Section 1: Unauthorised access to computer material

- **Actus Reus:** Causing a computer to perform any function (executing a command, probing a port, logging in) to secure access to program/data.
- **Mens Rea:** Access is unauthorized, and the individual knows it is unauthorized.
- **Distinguishing Factor:** No damage is caused, no secondary crime intended.
- **CREST Exam Traps:** Scanning a mistyped IP address is a Section 1 violation (lack of authorization). There is no "ethical hacking" or "public interest" defense.

Section 2: Unauthorised access with intent to commit further offences

- **Actus Reus:** Committing an offense under Section 1.
- **Mens Rea:** Specific intent to commit/facilitate an arrestable offense carrying 5+ years (e.g., Fraud Act 2006, Theft Act 1968, Blackmail).
- **Distinguishing Factor:** The secondary offense does not need to be committed simultaneously; the intent alone triggers Section 2.

Section 3: Unauthorised acts with intent/recklessness to impair operation

- **Actus Reus:** Unauthorized act causing impairment of operation, hindering access, or impairing reliability of data.
- **Mens Rea:** Direct intent OR recklessness.
- **Distinguishing Factor:** If a pentester runs an intrusive buffer overflow or unthrottled scanner without evaluating server stability and crashes production, they can be prosecuted under Section 3 due to reckless behavior.

Section 3ZA: Unauthorised acts causing serious damage

- **Added by:** Serious Crime Act 2015.
- **"Serious Damage" Criteria:** Damage to human welfare (loss of life, illness), the environment, UK economy, or national security.
- **Penalty:** Up to 14 years, or Life imprisonment if human life/national security is endangered.

Section 3A: Making/supplying articles for use in computer misuse

- **Added by:** Police and Justice Act 2006.
- **Subsections:** (1) Making/adapting with belief it will be used maliciously. (2) Supplying an article

likely to be used in an offense. (3) Obtaining an article to commit an offense.

- **The Dual-Use Defense:** Security tools (Nmap, Metasploit) have legitimate utilities. Prosecution must prove criminal intent or subjective belief that the tool will be used maliciously.

Sections 4–9: Territorial Scope ("Significant Link")

UK courts claim jurisdiction if ANY single condition is satisfied:

- The suspect was physically located in the UK at the time of the act.
- The targeted machine or data was located in the UK.
- Any intermediary server used to bounce, forward, or route traffic was located in the UK.

4. Privacy, Human Rights & Interception

PRIVACY & DATA

Data Protection Act (DPA 1998 / 2018 & UK GDPR)

- **Data Minimisation:** Collect only the minimum personal data necessary to establish proof-of-concept. Extract 1–2 masked rows, never download 50,000 customers.
- **Integrity and Confidentiality:** Evidence, credential lists, and memory dumps must be stored in encrypted volumes (AES-256) and securely destroyed after sign-off.
- **Storage Limitation:** Test data must not be retained longer than specified in the Statement of Work.
- **Data Controller vs Processor:** The client is the Controller; the security testing firm is the Processor.
- **Breach Notification (Article 33):** Compromises must be reported to the ICO within 72 hours.

Human Rights Act 1998 (HRA) — Article 8

- **Protection:** Right to respect for private and family life, home, and correspondence.
- **The Pentesting Boundary:** Personal emails or photos stored on a corporate device fall under Article 8. If discovered, the tester must pause, not read/exfiltrate them, document the exposure path safely, and notify the client.

RIPA 2000 & Investigatory Powers Act 2016 (IPA)

- **Core Offense:** Unlawful intentional interception of communications in transit.
- **Pentesting Risks:** Inline network taps, ARP cache poisoning, or VoIP capturing without explicit scope authorization.
- **Lawful Business Practice Regulations (LBPR) 2000:** Permits businesses to monitor their own networks without employee consent for specific authorized purposes (security, compliance). Pentesters rely on this delegated authority.

NIS Regulations 2018

- Regulates Operators of Essential Services (energy, water, health, transport) and Relevant Digital Service Providers (search engines, cloud).
- Requires incident notifications to competent authorities within 72 hours.

5. Rapid Decision Flowchart: How to Answer Legal MCQs

DECISION LOGIC

```
[Is the target system or data accessed/modified without permission?]
        |
        ├─► YES ──► Was there ANY physical damage, crash, or service degradation?
        |             |
        |             ├─► YES ──► Did it endanger critical infrastructure or human life?
        |             |             |
        |             |             ├─► YES ──► CMA 1990 – Section 3ZA (Life Max)
        |             |             └─► NO  ──► CMA 1990 – Section 3 (Impairment / Recklessne
        |             |
        |             └─► NO  ──► Was there intent to commit fraud, theft, or serious crime?
        |                           |
        |                           ├─► YES ──► CMA 1990 – Section 2
        |                           └─► NO  ──► CMA 1990 – Section 1 (Unauthorized Access)
        |
        └─► NO (Target is In-Scope with signed contract)
              |
              ├─► Did the tester distribute/build exploit code for malicious use?
              |    └─► CMA 1990 – Section 3A (Articles for Misuse)
              |
              ├─► Did the tester read personal emails or private files of an employee?
              |    └─► Human Rights Act 1998 – Article 8 (Right to Privacy)
              |
              ├─► Did the tester dump excessive customer PII or store it unencrypted?
              |    └─► DPA 2018 / UK GDPR (Breach of Minimisation / Security)
              |
              ├─► Did the tester sniff network traffic / ARP poison without client consent?
              |    └─► RIPA 2000 / IPA 2016 (Interception)
              |
              └─► What amended Section 3 to include DoS and created Section 3A?
                   └─► Police and Justice Act 2006
```